대외비 2급

사용자 보안관리 지침서

2012. 02

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM

제 개정 이력

제 개정번호	일자	제 개정 내용 요약	작성자
2012-01	2012-02-22	ISO27001 인증 대비 전면 개정	조남인
2013-01	2013-07-17	제6장제24조⑤ 문구 수정, 제28조①, ② 및 제29조① 신설 [별지 제3호 서식] 신설	조남인
2016-01	2016-01-29	제5조 (책임소재) 제2항 신설 [별지 제2호 서식] 개인용 인증서 신청서 서식 변경	조남인
2017-01	2017-06-14	제41조 (자리비움 시의 기기보안) ② 신설	조남인
2018-01	2018-03-15	제18조 (네트워크 사용) 정보통신팀 → 정보보안팀	조남인
2019-01	2019-04-24	제26조 (전자메일 사용자 계정 및 암호) 퇴직자 전자메일 사용 제한 및 연장 절차 확립	조남인
2019-02	2019-10-22	제12조(사용자 암호 사용 및 비밀번호 관리) ⑦항반기→분기 제39조,제40조삭제(타지침서와중복)	조남인
2020-01	2020-11-04	제1조(목적) 의료정보시스템으로한정된문구삭제 제17조 (경영자정보접근권한정책) 조항삭제 제18조(네트워크사용) ITSM 사용절차로변경 제37조(공유폴더제한) 공유폴더사용시간삭제	조남인
2022-01	2022-05-13	제9조(사용자계정의삭제) 제12조(사용자암호사용및비밀번호관리)	조남인
2023-01	2023-01-04	제18조(네트워크사용) 제29조(전자메일의관리및운영)	조남인
2023-02	2024-01-08	제8조(사용자 계정 관리) 제16조(ocs/emr 권한관리 정책) 제23조(이메일 및 인터넷 게시물 사용 로그 수집) 제24조, 제25조 삭제 제26조(전자메일 사용자 계정 및 암호) 제29조(전자메일 관리 및 운영)	조남인
2024-01	2024-12-23	제12조(사용자 암호 사용 및 비밀번호 관리) 제26조(전자메일 사용자 계정 및 암호) 제29조(전자메일의 관리 및 운영)	조남인

목 차

제1조 (목적) 4
제2조 (적용범위) 4
제3조 (용어의 정의) 4
제4조 (책임과 역할) 5
제5조 (책임소재) 5
제6조 (사용자의 의무) 6
제7조 (접근통제 정책) 6
제8조 (사용자 계정 관리) 7
제9조 (사용자 계정의 삭제) 7
제10조 (사용자 식별 및 인증) 8
제11조 (사용자 등록 및 해지) 8
제12조 (사용자 암호 사용 및 비밀번호 관리) 9
제13조 (사용자의 특권 관리) 10
제14조 (사용자 접근권한의 검토) 11
제15조 (의료정보로의 접근제한) 11
제16조 (OCS/EMR 권한관리 정책) 11
제18조 (네트워크 사용) 12
제19조 (인터넷 설치 및 설치의 제한) 13
제20조 (접속사이트 제한) 13
제21조 (사용량 통제) 13
제22조 (사용자 웹 브라우저 보안 기능 강화) 14

제23조 (이메일 및 인터넷 게시물 사용 로그 수집) 14
제24조 삭제 <2024.01.08> 15
제25조 삭제 <2024.01.08> 15
제26조 (전자메일 사용자 계정 및 암호) 15
제27조 (전자메일 사용자의 의무) 16
제28조 (전자메일 열람 및 보안) 16
제29조 (전자메일의 관리 및 운영) 17
제30조 (소프트웨어 설치 및 관리) 18
제31조 (불법 소프트웨어) 18
제32조 (바이러스 방지) 18
제33조 (악성코드 방지대책) 19
제34조 (바이러스 대응) 20
제35조 (PC 등 전산장비 보안관리) 21
제36조 (모바일 컴퓨팅) 23
제37조 (공유폴더 제한) 23
제38조 (데이터 보관) 24
제39조 삭제 <2019.10.22> 24
제40조 삭제 <2019.10.22> 24
제41조 (자리비움 시의 기기보안) 24
제42조 (클린데스크 및 클리어스크린 정책) 24
제43조 삭제 <2020.09.04> 25
제44조 (시행과 갱신) 25

제1장 총 칙

제1조 (목적)

본 지침서는 연세대학교 의료원 (이하 산하기관 모두 포함하여 '의료원'이라 칭함)은 사용자들이 준수해야 할 사항을 정하여 내.외부적 또는 우연적.고의적 위협으로부터 정보자산을 보호하는데 그 목적이 있다.

제2조 (적용범위)

본 지침은 의료원에 근무하는 전 교직원을 대상으로 적용되며, 의료원의 정보 자산에 접근하는 파견업체나 협력업체 등 의료원 소속 외의 모든 구성원에 적용된다.

제3조 (용어의 정의)

① "프로세스"란 조직의 정책 및 표준에 의해서 처리되는 과정을 말한다.

② "클린데스크"란 개인정보 및 중요 정보를 다루는 종사자는 업무가 종료될 시 혹은 자리를 이석할 경우에는 책상 위의 민감한 정보를 포함하는 모든 서류는 정보가 유출되지 않도록 관리되어야 하는 것을 말한다.

③ "클리어스크린"이란 개인정보 및 중요 정보를 다루는 단말기상에서 민감한 정보를 다룸으로 인해 고객의 시각에 의해 유출될 수 있는 자료를 보호하기 위한 통제수단을 말한다.

④ "시스템 유틸리티"란 정보시스템상에 설치된 각종 명령어 및 사용자의 목적에 맞게 벤더에서 개발, 제공된 프로그램 일체를 말한다.

⑤ "응용프로그램"이란 정보서비스를 제공하기 위하여 작성한 프로그램을 말한다.

⑥ 도메인 계정(AD) : 본 지침서의 도메인 계정(AD)이라 함은 현업 사용자가 그룹웨어, 전자메일 등을 사용하기 위해 생성된 계정을 말한다.

⑦ 직번 계정(ID) : 본 지침서의 직번 계정(ID)이라 함은 현업 사용자에게 부여된 직원 번호로 u-Severance 응용프로그램을 사용하는 계정을 말한다.

제4조 (책임과 역할)

① 최고정보보호책임자 : 의료원의 정보시스템 총괄 책임자로서 의료원 정보보호와 개인정보보호 책임자 역할을 겸직 수행한다.

② 정보보호책임자 : 최고정보보호책임자에 의해 위임된 정보보호 업무를 수행한다.

③ 정보보호관리자 : 소속 부서장으로서 부서의 정보보호와 개인정보보호를 직접 수행하며 부서 보안사고에 대한 책임을 진다.

④ 정보보호실무책임자 : 정보보호 주관 부서장으로서 전사적인 정보보호와 개인정보보호 정책 수립 및 이행하며 정보보호관리자(각 부서장)의 정보보호 활동을 지원한다.

⑤ 정보보호 및 보안 실무담당자 : 정보보호실무책임자가 임명한 정보보호 및 개인정보보호 업무 담당자로서 의료원 정보보호 및 개인정보보호를 위한 관리적/물리적/기술적 부문에서 각 부서의 관련 제반 업무를 지원하며 본 지침서의 이행 점검을 수행한다.

⑥ 부서 정보보호담당자 : 정보보호관리자(소속 부서장)가 임명한 부서의 정보보호담당자로서 의료원 정보보호 정책이 이행될 수 있도록 부서 내에서 정보보호 업무를 성실히 수행한다.

⑦ 계정관리담당자 : 그룹웨어 계정(AD)와 직번 계정(ID)을 생성/변경/삭제를 담당하며 장기 미사용 계정을 점검한다.

⑧ 사용자 : 직번 계정(ID)과 도메인 계정(AD)을 부여받아 정보시스템에서 제공하는 서비스를 이용하여 업무를 처리하거나 정보를 획득하는 자로서 의료원 교직원뿐 아니라, 파견업체나 협력업체 등 외부자를 포함하며, 사용자는 의료원의 정보자산을 보호하고, 정보보호 규정 및 지침서를 성실히 준수해야 할 의무를 갖는다.

제5조 (책임소재)

① 본 지침서를 이행하지 않은데 대한 모든 책임은 1차적으로 사용자 본인에게 있다.

② 부서에서 관리하는 개인정보 및 대외비 이상의 기밀문서에 대해 분실, 도난, 유출, 변조,

훼손 등의 보안사고 발생 시 모든 책임은 1차적으로 담당자 본인에게 있으며 2차적으로 해당 부서장(정보보호관리자)에게 있다.

제2장 사용자 보안

제6조 (사용자의 의무)

① 모든 사용자들은 정보시스템을 사용함에 있어 다음 각 호의 사항을 특별히 준수하여야 한다.

1. 정보시스템은 업무를 목적으로 사용하여야 하고, 계정(ID)에 대한 비밀번호를 반드시 설정하여 관리하여야 한다.
2. 정보시스템은 허가된 접근 권한 이내에서만 사용하여야 하고, 허가된 사용이라 하더라도 정당한 사유 없이 정보의 수집 및 열람 행위를 하여서는 안 된다.
3. 업무상 직/간접적으로 알게 되는 환자 및 직원의 개인정보를 이용 목적에 맞게 활용하여야 하고, 유출 또는 공개하여서는 안 된다.
4. 바이러스 감염 여부를 주기적으로 점검하고 감염 확인시 즉시 치료하여야 한다.
5. 정보보호 기능을 설정하는 등 의료원의 정보보호 정책에 적극 협조하여야 하며, 업무와 관련된 개인정보를 저장하여서는 안된다.
6. 정보보호 관련사고, 바이러스에 의한 피해 및 각종 위반이 발생할 경우 즉시 정보보호관리자(소속 부서장)와 정보보호 주관부서로 신고하여야 한다.

② 사용자는 “정보보호 가이드북”을 준수해야 하며 정보보호실무책임자는 “정보보호 가이드북”을 의료원 내외부 환경 변화 발생 시 개정하여 전 부서에 배포하여야 하며 정보보호관리자(각 부서장)는 해당 부서 내 교직원에 대해 교육을 수행하여야 한다.

③ 사용자는 “보안의 날”에 수행되는 정보보호 활동에 적극적으로 임해야 한다.

제7조 (접근통제 정책)

① 접근통제에 대한 업무 요구사항, 방법 등을 정의하여 문서화하고, 접근권한은 접근통제 정책에 정의 한대로 적절히 반영하여야 한다.

1. 개개인의 업무에 대한 보안 요구도
2. 정보를 처리하기 위한 업무프로그램이 가지고 있는 자료의 성격에 따라 적절한 보안수준을 결정한다.
3. '접근통제'의 각 기능을 분리, 운영한다.
4. 접근통제 정책을 주기적으로 검토한다.
5. 필요하지 않는 접근권한을 검토 후 제거한다.

제3장 계정(ID) 및 비밀 번호 관리

제8조 (사용자 계정 관리)

① 사용자 계정의 등록은 부적절한 시스템 사용을 통제하고, 사용자 별로 적절한 시스템 사용 권한을 부여하기 위해 사용자 등록은 공식적인 절차에 따라 수행한다.

1. 그룹웨어 계정(AD)은 ITSM을 통하여 정보보호관리자(소속 부서장)의 승인을 받아 신청한다.
2. 그룹웨어 계정(AD)은 개인 별로 부여함을 원칙으로 하되 공통 계정이 필요한 경우 공통 계정 생성 사유를 기재하고 신청한다.
3. 계정은 사용자의 사용권한이 소멸되는 사유가 발생하지 않는 한 변경하지 않으며, 직무 변경으로 권한 변경이 발생할 경우 권한에 대한 변경만 실시한다.

② 전자서명이 필요한 경우 인적보안 지침서에 따라 "개인용 인증 신청서"를 작성하여 관련 부서에 제출하여 공인인증서를 부여 받아야 한다.

제9조 (사용자 계정의 삭제)

① 사용자의 퇴직이나 외주 업무의 종료 등으로 사용자 계정이 삭제되는 경우에는 다음과

같은 절차를 수행한다.

1. 인사운영팀은 퇴직자 발생 시 즉시 시스템에 반영하여 사용 불가상태로 한다.
2. 외주 직원의 경우에는 해당 업무를 주관하던 부서장이 해당 업무의 종료 사실을 즉각 관련 부서에 통보하여 삭제하며, 통보의무를 위반하여 보안 사고 발생 시 해당 업무 부서장이 책임을 져야 한다.
3. 삭제 대상 계정은 즉시 삭제 또는 사용 불가 상태로 수정한다.
4. 계정관리담당자는 3개월 이상 미사용 계정을 점검하여 해당 부서 정보보호담당자에게 통보하며 부서 정보보호담당자는 이를 확인하여 계정관리담당자에게 사용 여부를 통보하고, 계정관리담당자는 미사용 계정일 경우 사용 불가 상태로 변경하고, 정지 후 3개월 내에 복원 요청이 없는 경우 삭제한다. 단, 장기 휴직인 경우 미 사용계정을 삭제하지 않고 정지만 시킬 수 있다.

제10조(사용자 식별 및 인증)

① 의료원 정보시스템에 접속하는 모든 사용자는 운영자, 관리자, 사용자 별로 유일한 아이디를 부여하고 사용자의 식별을 처리하기 위한 적절한 인증기술을 선택하여 적용하여야 한다.

② 사용자의 인증시스템으로는 OTP, FIDO, 스마트카드, 공인인증서, 개인의 정보를 저장한 USB메모리, 정맥인식기 등을 사용할 수 있다.

제11조(사용자 등록 및 해지)

여러 사용자가 접근하는 모든 정보시스템 및 서비스에 대한 접근을 허용하는데 있어 사용자등록과 해지절차가 존재해야 한다.

① 사용자 각각 자신의 고유한 업무에 대한 유일한 사용자계정을 갖는다.

② 사용자는 의료정보 시스템에 접근하기 위해 부서장의 결재를 득하여 사용자 등록 및 해지를 신청한다.

③ 시스템에 접근하고자 하는 사용자는 명확한 권한을 부여 받아야 한다.

④ telnet, ftp, VPN 등 기존 접속 서비스는 물론 새로운 서비스로도 사용자 인증 기능을 확대 적용 할 수 있어야 한다.

⑤ 시스템에 허용된 서비스 이외에 불법적인 서비스 실행을 차단하여야 한다.

⑥ 사용자의 접속로그 기록은 유지한다.

제12조(사용자 암호 사용 및 비밀번호 관리)

① 관리부서 준수사항

1. 암호생성 관련부서에서는 개인정보보호와 관련된 법률 및 시행령, 시행규칙을 고려하여 비밀번호 생성규칙과 주기적인 변경 관리정책을 적용한다.
2. 의료원 정보보안 교육 시 비밀번호 관리에 대한 내용을 포함한다.

② 사용자 준수사항

1. 비밀번호의 취급, 관리를 담당한다.
2. 비밀번호를 기억하고, 항상 비밀을 유지한다.
3. 시스템에서 부여받은 초기 비밀번호는 즉시 변경하여 사용한다.
4. 비밀번호를 입력할 때 타인에게 노출되지 않도록 한다.

③ 암호화 요구

1. 전산장비 및 저장매체에 보관하고 있는 기밀유지에 필요한 정보는 암호화하여 보관한다.
2. 보안위험을 대비하기 위해 암호화, 전자서명, 인증 등의 대책이 적용되어야 한다.

④ 비밀번호의 사용

1. 사용자들은 비밀번호의 선택과 사용에 있어서 본 지침서를 준수하여야 한다.
2. 비밀번호는 기밀로 유지한다.
3. 안전하게 저장되지 않는 한 비밀번호 기록을 피하고, 개선된 저장방법을 사용한다.
4. 시스템 또는 비밀번호 손상의 가능성이 예견될 때마다 비밀번호를 변경한다.

5. 임시 비밀번호는 최초 접속할 때 변경한다.
6. 매크로 또는 기능키에 저장하는 것과 같은 자동화 프로세스에 비밀번호를 포함시키지 않는다.
7. 사용자 비밀번호를 공유하지 않는다.
8. 업무 및 비 업무 목적을 위해 동일 비밀번호를 사용하지 않는다.

⑤ 비밀번호 생성규칙 및 종류는 다음 문자 종류 중 2종류 이상을 조합하여 최소 10자리 이상 또는 3종류 이상을 조합하여 최소 8자리 이상의 길이로 구성해야 한다.

1. 영문 대문자(26개)
2. 영문 소문자(26개)
3. 숫자(10개)
4. 특수문자(32개)

⑥ 비밀번호는 알기 쉬운 단어나 연속적인 숫자, 생일, 전화번호 등 추측하기 쉬운 숫자, 또는 예측이 가능한 문자 조합의 사용을 금한다.

⑦ 비밀번호는 분기별 90일마다 1회 이상 반드시 변경해야 한다. 단, 시스템 운영상 필요하다고 생각되는 정당한 사유가 있는 경우 최고정보보호책임자의 승인을 받아 예외적으로 별도의 정책을 적용할 수 있다.

⑧ 비밀번호가 유출된 경우, 또는 유출이 의심되는 경우에는 즉시 변경한다.

제4장 사용자 권한 관리

제13조(사용자의 특권 관리)

① 비상 시(예: 침해사고대응, 시스템 복구 등)에 사용하기 위해 등록된 계정은 특별히 더 제한하고 통제하여야 한다. (시스템관련 암호 등)

② 운영체제, 데이터베이스, 프로그램 등 시스템 제품과 관련된 접근권한 및 특별한 특정권한이 필요한 목록을 파악한다.

③ 사용자의 권한은 필요 시에 업무에 의한 최소한의 권한으로 생성되어야 한다.

④ 생성된 계정의 로그기록은 유지하도록 한다.

제14조(사용자 접근권한의 검토)

① 개인별·업무별로 할당된 업무분장에 따라 의료원 정보를 다룰 수 있는 프로그램의 접근권한을 설정한다.

1. 사용자의 프로그램 접근권한은 주기적으로 검토되어야 한다.
2. 사용자 접근권한은 동일 사용자가 같은 조직 내에서 다른 곳으로 이동한 경우 즉시 변경되어야 한다.
3. 사용자 별 특별권한을 부여한 계정에 대해 주기적인 계정 검토 작업이 이루어져야 한다.
4. 계정사용 등록 및 해지 신청에 의거 허가되지 않는 계정을 주기적으로 검토한다.

제15조(의료정보로의 접근제한)

① 의료정보 및 시스템 기능에 대한 접근은 정의된 접근통제 정책에 따라 제한하여야 한다.

1. 의료정보 시스템에 접근을 통제하기 위한 관리적 기능을 마련한다(사용자 계정에 대한 프로그램 접근권한 부여/제거 등)
2. 자료의 읽기/쓰기/삭제/출력 등의 권한은 사용자 별로 할당된 업무분장과 보안수준에 따라 부여하여야 한다.
3. 다른 응용프로그램에서 접근이 허용되지 않는 프로그램으로 강제적으로 이동하여 실행하는 것 등을 제한하여야 한다.

제16조(OCS/EMR 권한관리 정책)

① 의료정보를 보호하기 위하여 소속, 직무, 직위에 따라 직종을 분류하고 직종별 접근권한을 부여한다. 자세한 사항은 세브란스 내규 '14.5 의무기록정보 접근권한'의 내용을

따른다.

② 신규 교직원 및 퇴직자, 부서이동

1. 신규 교직원은 인사정보 입력 시 접근 권한을 부여하거나 발령 부서의 부서장이 확인 후 부여한다
2. 퇴직정보가 입력되면 접근 권한은 자동 해지되며, 퇴직 후 미비 점검을 위해서는 권한을 별도 부여한다.
3. 부서이동 발령 시 이전 부서장이 권한을 재 부여한다.
4. 의료원 소속 교직원이 아닌 경우는 별도 신청 절차를 거쳐 부여받을 수 있다.

3 ~11 삭제 <2024.01.08>

12 정보 접근 이력

1. 누가, 언제 어떤 기록을 열람 했는지 확인 가능하도록 기록 열람이력을 남긴다.

제 17조 삭제 <2020.09.04>

제5장 네트워크 및 인터넷 사용

제18조(네트워크 사용)

① 모든 사용자는 의료원 내의 네트워크를 사용하기 위해 다음 절차를 따라야 한다.

② 원내 네트워크를 사용하기 위해서는 ITSM을 통하여 부서장 승인 후 제출하여야 한다.

③ 내부 네트워크의 사용은 의료원 교직원만이 사용이 가능하다. 단, 부서의 업무 특성을 고려하여 외부 직원이 네트워크 사용이 필요할 경우 부서장이 승인신청서를 제출하여 관련 부서 승인 후 네트워크 사용이 가능하며, 이에 따른 책임은 해당 부서장에게 있다.

④ 내부망과 외부망을 혼용하여 사용해서는 안 되며, 부주의한 네트워크 사용에 따른 해킹 및 침해사고 발생시 이에 따른 법적, 민사상의 책임은 해당 사용자에게 있다.

⑤ 무선랜 사용자는 사용자 ID 또는 개인 비밀번호를 타인에게 노출하여서는 안 된다.

⑥ 정보보호실무책임자는 보안사항 미준수 사용자의 네트워크 사용을 차단할 수 있다.

제19조(인터넷 설치 및 설치의 제한)

① 업무상 인터넷 접속이 필요한 경우 의료원의 보안이 침해되지 않도록 각별히 주의해야 하며, 안전한 방법을 숙지하여 사용해야 한다.

② 진료실, 검사실, 수술실, 병동, OCS 전용, PACS 전용 PC의 경우 바이러스 감염 등 이에 따른 해킹 등의 피해를 막기 위해서 원칙적으로 인터넷 사용을 차단한다.

③ 환자망은 내부망과 분리되어 운영되며, 인터넷 설치 시 환자망의 유선 연결 또는 환자용 무선랜으로 접속하도록 하여 보안유출사고를 방지하여야 한다.

④ 학생용 인터넷은 내부망과 분리되어 운영되며, 인터넷 설치 시 학생망의 유선 연결 또는 학생용 무선랜으로 접속하도록 하여 보안유출사고를 방지하여야 한다.

⑤ 인터넷 오용 및 부주의에 의한 모든 법적・민사적 책임은 해당 사용자에게 있다.

제20조(접속사이트 제한)

① 전산망을 통하여 인터넷을 사용할 경우 다음 각 호의 카테고리 사이트 접속을 차단한다.

1. 범죄행위, 기타 부정행위, 음란, 폭력물 관련 사이트
2. 타인의 권리를 침해, 명예를 비방・훼손하는 내용이나 사회적 혼란을 야기시키는 사이트
3. 증권투자, 도박, 사행심을 부추기는 내용 및 사적인 영업행위를 목적으로 하는 사이트
4. 만화, 게임, 채팅, 개인 블로그등과 같은 개인적인 사이트

② 단, 환자용 인터넷은 증권 및 블로그, 게임사이트의 접속을 허용한다.

제21조(사용량 통제)

① 의료원 인터넷은 인터넷 대역폭 보호 및 속도 저하 방지를 위해 멀티미디어 서비스는

선별적으로 제한한다. (예: MP3, Real Video, Real Audio, VOD)

단, 교육 목적으로 제공되는 사이트는 예외로 허용한다.

② 인터넷을 통하여 업무와 관련이 없는 동영상 파일이나 프로그램 등을 다운 받지 말아야 한다.

제22조(사용자 웹 브라우저 보안 기능 강화)

① 인터넷을 사용하는 모든 사용자는 인터넷사용 시 보안 유출 및 해킹의 위험성을 줄이기 위하여 다음과 같은 웹 브라우저 보안 기능을 수행하여야 한다.

1. 웹 브라우저의 각종 보안 패치 및 서비스 팩을 설치한다.
2. 인터넷 옵션의 자동완성 기능을 해제하여 사용자 이름 및 암호가 자동적으로 입력되지 않도록 한다.
3. ActiveX 컨트롤 및 플러그인과 Java Applet 등 모바일 코드 사용이 필요할 경우 신뢰할 수 있는 업체가 제공하는 것인지 우선 확인한다.
4. 인터넷 게시판에 의료원의 업무 정보나 주요 기밀사항을 게시하지 말아야 한다. 또한, 업무와 상관없이 타인의 명예를 훼손하는 등의 목적으로 인터넷 게시판을 사용하지 말아야 한다.

제6장 전자메일 및 전자 게시판 사용

제23조(이메일 및 인터넷 게시물 사용 로그 수집)

① 의료원은 민・형사상 소송에 따른 법원 영장이나 검찰 등 수사기관의 법적 구속력 행사와 인터넷을 통한 의료원 중요 정보자산의 외부 유출사고 발생 시 향후 추적성을 강화하기 위해 사용로그를 수집한다.

② 전자우편(의료원 메일 외부 발송, POP3, SMTP)에 대한 제목, 본문, 첨부파일을 수집하여 저장한다.

③ ~ ⑤ 삭제 <2024.01.08>

⑥ 의료원 보안정책 위반 및 정보유출사고가 발생하였을 때 해당 교직원에게 통보하도록한다.

제24조 삭제 <2024.01.08>

제25조 삭제 <2024.01.08>

제26조(전자메일 사용자 계정 및 암호)

① 전자메일 사용으로 인한 개인정보 유출, 보안위협 방지를 위해 전자메일 계정 생성 및 삭제 통제를 실시하여야 한다.

② 전자메일 사용자 계정 및 암호 관리는 '제12조(사용자 암호 사용 및 비밀번호 관리)에 준한다.

③ 전자메일 사용신청서는 ITSM을 통하여 작성 및 부서장 승인 후 신청한다.

④ 다음 각 호에 해당하는 사용자의 전자메일 계정은 삭제한다.

1. 퇴직자
2. ID 등록 신청서에 허위 내용을 기재하여 등록된 사용자
3. 타 사용자에 대한 개인 정보를 동의 없이 수집, 저장, 공개하는 사용자
4. 퇴직 이후 이메일 연장 사용자 중 6개월 이상 이메일 사용 접속 기록이 없는 사용자

⑤ 퇴직자 중 다음 각 호에 해당하는 사용자는 의료원 이메일을 계속 사용할 수 있다.

1. 서면으로 사용 연장 신청을 한 명예교수 (기간 제한은 없으나, 매년 연장 신청 필요)
2. 다음의 사유에 해당하는 경우에 한하여 부서장의 결재가 포함된 신청서를 제출한 사용자
   1) 의료원의 잔여 업무처리가 있는 경우(구체적인 업무내역 기재)
   2) 공동연구 잔여 기간이 있는 경우
   3) 논문 진행 잔여 기간이 있는 경우

4) 의료원 산하 박사후 과정의 신분인 경우

3. 2호 해당사항 외 연장이 필요한 경우 구체적인 사유를 기재하여 기관장의 결재가 포함된 신청서를 사용한 사용자
4. 사용 연장 신청 시 사용 기한은 1년으로, 1년 이상 사용이 필요한 경우 1년 단위로 신청서를 제출한 사용자
5. 명예교수를 제외한 퇴직자(최대 3년)
   가. 최초 이메일 연장 신청 시 : 1년간 수/발신 가능
   나. 추가 연장은 2년 가능 : 수신 가능, 발신 차단
6. 퇴직자 이메일 연장 시 의료원 공지사항 수신 권한은 제거한다. 단, 업무상 반드시 필요한 경우 소속기관장의 결재가 포함된 공문을 제출하여야 한다.

제27조(전자메일 사용자의 의무)

① 전산망을 통한 전자메일 사용자는 다음 각 호에 해당하는 행위를 하여서는 안되며, 건전하고 신뢰성 있는 환경 조성을 위하여 최대한 노력하여야 한다.

1. 직무와 관련 없는 개인적인 내용이나 개인에게 국한된 사안(부당한 대우, 상사와의 갈등 등)을 불특정 다수에게 발송하는 행위
2. 의료원의 기밀 자료를 허가 없이 외부로 유출하는 행위
3. 의료원 전자메일 주소록을 외부로 유출하는 행위
4. 의료원 또는 타인을 비방하거나 업무 방해를 유도하는 행위
5. 타인의 ID를 도용하거나 범죄행위와 관련된 내용을 발송하는 행위
6. 외설, 폭력적인 메시지, 스팸 메일, 행운의 편지, 다단계사업을 권유하는 등 영업을 목적으로 하는 메일, 컴퓨터 바이러스 등을 발송하는 행위

제28조(전자메일 열람 및 보안)

① 의료원은 외부기관에서 영장 수사 등 법령상 의무를 준수하기 위하여 의료원 메일 열람

요청 시 의료원장 보고 후 열람할 수 있도록 한다.

② 의료원은 내부에서 자료유출 및 보안사고 등 의료원이 업무수행을 위하여 메일 열람이 필요할 경우에는 “[별지 제3호 서식] 전자메일 열람 요청서”에 의거 의료원장의 승인을 득한 후 감사팀 입회하에 열람할 수 있도록 한다.

③ 사용자는 의료원의 자산을 보호하고 유지하기 위해 다음과 같은 전자메일 사용 지침을 준수하여야 하며, 이를 위반하여 문제가 발생하는 경우 행위자 본인의 책임이므로 반드시 준수하도록 한다.

1. 첨부파일이 있는 경우 반드시 바이러스 감염 여부를 확인 후 열람한다.
2. PC방과 같이 많은 사람들이 이용하는 공공장소에서는 업무에 관계되는 메일을 확인하거나 송・수신하지 않도록 한다.

제29조(전자메일의 관리 및 운영)

① 삭제 <2024.01.08>

② 전자메일 시스템의 안정화를 위하여 다음과 같은 조치를 취할 수 있다.

1. 사용자의 메일 발송 시 동시 수신자는 100명 이하로 제한한다.
2. 메일 첨부 파일의 사이즈는 70MB 이하로 제한한다.
3. 메일 사서함의 보관 용량은 교원 20GB, 교원 외 사용자는 5GB로 한다.
4. 전체공지, 알림 메일 발송 시 기관별 공지사항 ID를 사용하도록 한다.
5. 확장자 exe, bat, scr 등의 첨부파일은 바이러스 유형으로 차단한다.
6. 상업성 전자메일은 수신을 차단한다.
7. 외부에서 수신되는 전자메일은 역방향 DNS (Domain Name System) 조회 후 공식적인 DNS가 아닌 경우 수신을 차단한다.

제7장 소프트웨어 관리

제30조(소프트웨어 설치 및 관리)

① 소프트웨어 설치는 반드시 의료원에서 정한 정품 또는 개인이 정식으로 구매한 정품 소프트웨어에 한해 설치하여야 한다.

② 의료원에서 정하지 아니한 불법 소프트웨어를 설치하여 문제가 발생하였을 경우에는 불법 소프트웨어 사용에 따른 법적・민사적 책임은 해당 사용자에게 있다.

③ 의료원에서 제공한 상용소프트웨어 및 응용 프로그램(u-Severance)등을 소속 부서장의 허락 없이 무단으로 타인에게 복사해 주어서는 아니 된다.

제31조(불법 소프트웨어)

① 의료원 및 개인이 정식으로 구입한 정품 소프트웨어만을 사용하여야 하며, 통신망을 통한 출처가 불분명한 소프트웨어는 사용하지 말아야 한다.

② 쉐어웨어(shareware, 사용기간이 명시되어 있거나 기능의 제약이 있는 소프트웨어)의 경우는 사용을 금지하고, 프리웨어도 개인용도로만 사용이 허가되어 있는 것은 사용을 금지한다.

③ 법적 제약 조건의 해석이 어려운 경우에는 관련부서에 문의하여 해석을 의뢰한다.

④ 의료원에서 구입하지 않은 소프트웨어를 반드시 사용하여야 하는 경우에는 사용하기 이전에 반드시 지적 재산권과 같은 법적 제약이 존재하는지 확인 절차를 거쳐야 한다.

제8장 바이러스 및 악성코드 대응

제32조(바이러스 방지)

① 바이러스 방지를 위해서는 antivirus 제품에 대한 사용자들의 적절한 사용이 요구되며, 사용자들은 반드시 아래의 지침에 따라 PC를 설정하여야 한다. 또한, 바이러스 백신이 설치된 서버급 시스템에서도 아래의 항에 따라 바이러스 방지 활동을 수행하여야 한다.

② 사용자는 반드시 의료원 도메인 계정으로 로그인하여 자동으로 윈도우 보안업데이트, 바이러스 백신 설치 및 자동 업데이트 정책을 적용 받아야 한다.

③ 각 사용자는 의료원 도메인 참여 시 로그인 절차를 통하여 바이러스 백신 프로그램의 설치 유무를 확인할 수 있으며, 미 설치 시에는 의료원 바이러스 정책에 의하여 반드시 설치를 하여야 한다. 또한, 바이러스 백신 프로그램 미 설치 시 의료원 인터넷을 차단한다.

④ 외부에서 임시 사용을 위하여 반입된 PC의 경우 도메인 접속 절차를 경유하지 않고, 각 부서 정보보호담당자를 통하여 바이러스 백신 프로그램을 설치하여야 한다. 미 설치시 인터넷 사용을 차단한다.

⑤ 환자 및 학생용 네트워크를 사용하는 사용자는 환자용 및 학생용 바이러스 백신 프로그램을 설치하여야 하며, 인터넷 접속 시 바이러스 백신 프로그램 미 설치 안내창을 표시하여 백신 프로그램을 설치하도록 한다.

⑥ 환자 및 학생용 바이러스 백신 프로그램 미 설치 시 인터넷 접속을 차단한다.

⑦ 바이러스 백신 자동 보호 기능의 설정으로 바이러스로부터 시스템을 계속적으로 보호할 수 있도록 하여야 한다.(기본 정책으로 실시간 감지가 설정되어 있으므로 실시간 감시가 실행되고 있는지 확인 필요)

⑧ 새로운 바이러스에 대해서 주기적으로 검사하도록 매주 1회 이상의 예약 검사가 설정되어 있어야 한다. 단, 서버급 시스템의 경우는 매주 1회 이상 바이러스 검사를 하도록 예약검사가 설정되어 있어야 한다.

⑨ 새로운 바이러스 패턴에 대한 정의를 다운로드 받을 수 있도록 자동 live update 항목이 설정되어 있어야 한다.

⑩ 사용하던 PC에 이상 징후(갑작스러운 시스템 성능의 저하, 하드 디스크의 계속적인 접근 등)가 발생 시에는 즉시 바이러스 검사를 수행한다.

제33조(악성코드 방지대책)

① 각 정보보안관리자(부서장)는 웜・바이러스, 해킹프로그램, 스파이웨어 등 악성코드 감염을 방지하기 위하여 다음 각 호에 따라 정보시스템 자산을 운영・관리해야 한다.

1. 출처, 유통경로 및 제작자가 명확하지 않은 응용프로그램은 사용을 자제하고,

불가피할 경우에는 백신 등 관련 검색 프로그램으로 진단 후 사용한다.

2. 실행파일은 읽기 전용으로 속성을 변경하여 사용한다.
3. 인터넷 등에서 수집한 자료는 필히 악성코드 검색 후 사용한다.
4. 악성코드 조기 발견을 위하여 최신 백신프로그램 활용 및 보안 업데이트를 실행한다.
5. 시스템이 작동할 때마다 컴퓨터 하드디스크의 부트섹터 및 메모리 등에 악성코드가 감염되었는지 주기적으로 점검한다.

② 악성코드 감염이 발견되었을 경우 시스템관리자 또는 PC 사용자는 다음 각 호의 조치를 취해야 한다.

1. 악성코드 감염피해를 최소화하기 위하여 감염된 시스템 사용 중지 및 네트워크 접속 분리
2. 최신 백신 등 악성코드 제거 프로그램을 이용하여 퇴치
3. 악성코드의 감염확산 방지를 위하여 관련부서에 보안조치 사항을 즉시보고
4. 악성코드 감염의 재발을 방지하기 위하여 원인 분석 및 예방 조치 수행

③ 정보보호관리자는(소속 부서장) 악성코드가 신종이거나 감염피해가 심각하다고 판단할 경우에는 해당사항을 관련부서에 신속히 통보하여야 한다.

제34조(바이러스 대응)

① 자신이 사용하는 PC또는 서버급 시스템에서 바이러스가 발견됐다면 사용자(담당자)는 다음과 같은 절차를 준수해야 한다.

1. 네트워크 선을 PC에서 분리하여 내부 네트워크 망과 차단한다.
2. 바이러스 백신 프로그램을 이용하여 바이러스를 치료한 후 감염 경로를 검사한다.
3. 바이러스 감염 경로가 정확히 파악되면 감염PC 사용자에게 즉시 바이러스 검사를 요청하여 확산을 방지한다.
4. 바이러스 감염 경로가 정확하지 않거나 감염 추정 규모가 클 경우는 즉시 관련 부서에 통보한다.

제9장 PC 등 전산 장비 및 보조기억매체 보안 관리

제35조 (PC 등 전산장비 보안관리)

① 업무용 PC 설치시 다음과 같은 소프트웨어를 설치하여야 한다.

1. PC 보안시스템 클라이언트 프로그램
2. 바이러스 백신 에이젼트 및 백신프로그램
3. 기타 최고정보보호책임자(디지털헬스실장)의 승인을 득한 프로그램

② 최고정보보호책임자는 통합PC보안시스템 또는 패치관리시스템을 이용하여 설치할 수 있으며, PC 보안 시스템 클라이언트를 설치하지 않은 PC에 대해서 사용제한 등의 제재를 가할 수 있다.

③ 각 기관 및 부서에서는 비 인가자가 전산장비를 무단으로 조작하여 전산 자료를 유출, 위·변조 및 훼손시키지 못하도록 다음 각 호에 정한 보안대책을 반드시 준수하여야 한다.

1. 전산장비 별 사용자 계정 및 암호 사용
2. 전산장비 작업 중단 시 화면 보호 조치(30분 이내 화면 보호 조치를 하며, 수술, 환자관리 등의 병원 업무를 위해 필요한 경우는 예외로 한다.)
3. 백신 설치 및 자동 업데이트 확인 의무화
4. P2P 등 업무와 무관하거나 보안에 취약한 프로그램의 사용 금지
5. 업무용PC는 부팅 패스워드(외부 반출 시), Windows 로그온 패스워드, 화면보호기 패스워드, 공유폴더 패스워드를 사용하여야 한다.

④ 정보보호관리자(소속 부서장)는 소속 부서의 전산장비를 교체·반납·폐기하거나 고장으로 외부에 수리를 의뢰하고자 할 경우에는 하드디스크에 수록된 자료가 유출, 훼손되지 않도록 보안 조치를 하여야 한다.

1. 업무용 PC의 반납 시 사용자는 사용 PC의 데이터를 완전삭제하고 정보보호관리자(소속 부서장)의 확인 후 반납한다.

2. 업무용 PC의 폐기, 매각 등 외부로 영구 반출 시 모든 데이터를 복원이 불가능하도록 사전에 조치하여야 한다. (예, 로우 레벨 포맷, 물리적인 파손 등)

⑤ 전산장비에 보관된 의료원 자료 및 출력물은 외부 및 타 부서(업무관련 부서 제외)로 해당 정보보호 관리자(소속 부서장)의 승인 없이 유출하여서는 안된다.

⑥ 원내 PC의 공유 폴더에 접근하여 임의로 파일 또는 폴더 복사 및 삭제 시 행위 내용(파일명, 접속IP, 접속 일시)에 대한 로그를 저장한다.

⑦ 정보보호관리자(소속 부서장)는 소속부서의 업무용 노트북, 전산장비 등 휴대용 전산장비의 운용현황을 파악하여 관리하고, 반출 또는 반입시 최신 백신을 활용하여 해킹프로그램 및 웜·바이러스 감염여부를 점검하여야 하며, 필요한 경우 담당 부서의 지원을 받도록 한다.

⑧ 전산장비의 위치를 사용자가 임의로 변경할 수 없으며, 부득이한 변경 사유가 있는 경우 사전에 관련 부서의 승인을 받도록 하며, 부여받은 IP를 임의로 변경해서는 안 된다.

⑨ 의료원 내에서 사용하는 모든 Windows 컴퓨터는 도메인에 가입한 후 반드시 도메인에 로그온 하여 사용해야 한다.

⑩ 사용자는 의료원에서 규정한 PC 기본 설정 환경을 임의로 변경해서는 안되며 도메인에 로그온 하여 위 ①항의 필수 프로그램은 전산장비 보안을 위한 장치이므로 임의로 제거하면 안 된다.

⑪ 사용자는 컴퓨터의 자동 업데이트 상태, 백신 업데이트 및 바이러스 감염 여부 점검 등에 주의를 기울여 정상 상태를 유지하도록 하고, 필요한 경우 관련 부서에 신고하여 정상 상태를 유지할 의무를 갖는다.

⑫ 부서내 공용컴퓨터는 관리자를 지정하고, 지침을 준수할 수 있도록 하며, 공용컴퓨터에는 기본 운영체계와 업무용 기본 프로그램 외 중요 자료가 저장되어 있으면 안 된다. (단, 업무 특성에 따라 중요 정보 등을 저장 시 접근 권한 부여한다.)

⑬ 위 사항을 위반 할 경우 이에 따른 책임은 해당 사용자에게 있다.

제36조(모바일 컴퓨팅)

① 최종 사용자가 노트북, 테블릿PC 같은 모바일 컴퓨팅 시스템을 이용하는 경우에는 사용환경의 다양성과 휴대의 간편성으로 인한 위험을 고려하여 적절한 보호 수단을 마련하여야 한다.

② 스마트폰 등을 사용하여 내부망 PC가 외부 인터넷에 접속하는 것을 차단한다.

③ 모바일 컴퓨팅 시스템은 부팅 패스워드가 지정되어 있어야 하며, 저장되어 있는 중요 정보는 암호화되어야 한다.

④ 모바일 컴퓨팅 시스템을 이용하여 외부에서 조직 내부 네트워크에 연결할 때에는 정보보호 주관부서에 의뢰하여 승인을 받고, 모바일 인증서 VPN을 배포 받아 접근 한다.

⑤ 모바일 컴퓨팅 시스템에 저장되어 있는 중요한 정보는 항상 백업을 수행하여야 한다.

⑥ 모바일 컴퓨팅 시스템은 절도로부터 보호될 수 있도록 취급상 주의를 기울이며, 안전케이블 또는 잠금 장치를 사용하여야 한다.

⑦ 출장 시는 별도의 출장용 노트북을 사용하여야 한다.

제37조 (공유폴더 제한)

① 공유폴더의 사용은 업무상 부득이하게 필요한 경우를 제외하고는 기본적으로 금지한다.

② 공유폴더를 사용 시 다음 사항을 준수한다.

1. 정보보호관리자(소속 부서장)은 필요한 업무 교직원에 한해 접속권한을 부여해야 하며 인사이동, 퇴사 등의 업무 발생시 해당 교직원과 접속권한을 제거한다.
2. 반드시 별도 폴더를 생성하여 공유하며, 공유폴더는 공유 목적 달성 시 즉시 제거한다.
3. 절대로 C: 혹은 D: 등의 Root 디렉터리 전체를 공유하지 않는다.
4. 특별한 이유 없이 모든 권한(쓰기권한 포함) 설정을 하지 않는다.
5. 제12조의(사용자 암호 사용 및 비밀번호 관리)를 준용하여 패스워드를 설정한다.
6. 공유폴더명에는 “$”를 사용하지 않는다.

③ 공유폴더 사용으로 인한 보안사고는 사용자와 정보보호관리자(소속 부서장)가 책임을 진다.

제38조(데이터 보관)

① PC에는 기밀 및 주요정보를 보관하지 않아야 한다.

② 업무상 부득이 노트북, 외장형 하드, USB메모리카드 등에 기밀 및 대외비 정보를 저장해야 하는 경우, 비밀번호 혹은 암호화 기법 등을 이용해 보안성을 확보하여 보관한다.

③ "기밀 및 주요정보(대외비 1급/2급)"에 해당하는 전자문서는 반드시 문서 패스워드를 설정하여야 하고 업무상 불필요한 인원과 공유하지 않아야 한다.

제39조 삭제 <2019.10.22>

제40조 삭제 <2019.10.22>

제10장 전산 장비 및 사무공간 물리적 보안

제41조 (자리비움 시의 기기보안)

① 모든 사용자는 자리를 비울 때 타인으로부터 의료정보 시스템 및 데이터를 보호하기 위한 책임이 있다는 것을 확실하게 인식하여야 하며, 이에 상응하는 조치(예: 로그아웃, 화면보호 스크린 등)를 취하여야 한다. 단, 수술, 환자관리 등의 병원 업무를 위해 필요한 경우는 예외로 한다.

② 모든 사용자는 업무 종료 후 PC 전원을 차단하여야 한다.

제42조(클린데스크 및 클리어스크린 정책)

① 사용자는 의료정보 등이 포함된 출력물을 보호하기 위하여 클린데스크를 수행하여야

한다.

② 컴퓨터, 단말기는 로그오프로 두거나 화면보호기 또는 키보드 잠금 장치로 보호해야 한다. 단, 수술, 환자관리 등의 병원 업무를 위해 필요한 경우는 예외로 한다.

③ 의료정보의 송수신할 목적으로 사용되는 팩스는 의료정보가 누출되지 않도록 보호해야 한다.

④ 의료정보가 포함된 문서가 인쇄될 경우 부서명/사용자 이름/출력일시 등의 정보가 문서에 삽입되어 인쇄되도록 한다.

제43조 삭제 <2020.09.04>

제44조(시행과 갱신)

상기 지침서의 시행과 갱신을 위한 상세한 세부사항은 정보보호규정 '제4장 정보보호 정책'에 준한다.

[별지 제1호 서식] 삭제 <2024.1.08>

[별지 제2호 서식] 삭제 <2024.1.08>

[별지 제3호 서식]

담당자	부서장	소 장	실 장	의료원장

전자메일 열람 요청서

신청인	부 서		직 번	
	성 명		생 년 월 일	
	전 화 번 호		휴대폰 번호	
신청내용	열람 계정	@yuhs.ac		
	용도 및 목적			
	열람 요청 상세내용			

1. 본인은 전자메일을 열람에 있어 기재한 용도 외에는 사용하지 않을 것이며, 제3자에게 유출하지 않는 것에 동의합니다.
2. 본인은 전자메일 열람 시 유출 등의 부주의로 발생하는 민Y형사상의 모든 문제는 본인이 책임질 것에 동의합니다.

20 년 월 일

신 청 자 : 성명 (서명 또는 인)

부서책임자 : 성명 (서명 또는 인)

기 관 장 : 성명 (서명 또는 인)